

Path Traversal using C:... allows to break out of root directory on Windows in mlflow/mlflow

✓ Valid

Reported on Aug 10th 2023

Description

In

<https://github.com/mlflow/mlflow/blob/d2f34c39c97f342e238a2d87a1c288cee825fcbe/mlflow/server/handlers.py#L525>. The checks can be bypassed using `C:...`.

If you don't know what starting a path on Windows with C: does, basically if a path starts with C: on Windows then we treat it such that we remove the drive letter and colon from the beginning. For instance a path `C:../.ssh/id_rsa` will get converted to `../.ssh/id_rsa`. As such we can break out of the root directory up to 1 layer. A good way to break out of the root mlflow directory is `/api/2.0/mlflow-artifacts/artifacts` endpoint. If we assume that the directory root is `C://Users/User/mlflowui`, then querying the endpoint `/api/2.0/mlflow-artifacts/artifacts` allows us to break out of the root `C://Users/User/mlflowui` directory and obtain files from `C://Users/User`, which can include the SSH key.

POC

In `C://Users/<User>` of your windows machine

- 1: Add secret text into `C://Users/<User>/.ssh/id_rsa`
- 2: Create `mlflowui` directory which you will run mlflow from there.
- 3: Run `mlflow ui` in `C://Users/<User>/mlflowui`
- 4: Then curl to retrieve the contents:

```
curl -vv "http://127.0.0.1:5000/api/2.0/mlflow-artifacts/artifacts/C:../.ssh/id_rsa"
```

Extra: You can also perform arbitrary file write on the system (which can overwrite models/data and cause RCE by overwriting the python files etc.) by performing a PUT instead of a GET

```
curl -X PUT --data-binary test "http://127.0.0.1:5000/api/2.0/mlflow-artifacts/arti"
```

Above overwrites `id_rsa` file.

Impact

Read sensitive data from Windows host (which can include the SSH key)

Severity taken from <https://huntr.mlsecops.com/bounties/1fe8f21a-c438-4cba-9add-e8a5dab94e28/>

More info about these paths <https://stackoverflow.com/questions/23955968/windows-path-with-no-slash-after-drive-letter-and-colon-what-does-it-point-to>

References

- <https://stackoverflow.com/questions/23955968/windows-path-with-no-slash-after-drive-letter-and-colon-what-does-it-point-to>

⚙ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

🔗 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



haxatron commented 2 years ago

Researcher

@admin can someone explain what ml specific impact means? that part is unclear



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



haxatron commented 2 years ago

Researcher

I am changing ML modifiers to Models: W; Data: W; Asset: One, as the path traversal also allows overwriting arbitrary files (which include model / data and such)



haxatron commented 2 years ago

Researcher

@admin, feel free to correct if I am incorrect on the application of ML modifiers



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago

✉ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



haxatron commented 2 years ago

Researcher

@admin, user identity startsWith is not a function while submitting the fix?

Patch is here anyway:

<https://github.com/mlflow/mlflow/compare/master...Haxatron:mlflow:master>



↑ haxatron submitted a patch 2 years ago



Ben Harvie commented 2 years ago

Admin

Hey haxatron, sorry that was a bug on our side that has now been fixed, your patch has been submitted successfully now.



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



✎ haxatron modified the report 2 years ago



haxatron commented 2 years ago

Researcher

bump



haxatron commented 2 years ago

Researcher

hello @admin, as 30 days have passed, may I have the go ahead to send in the PR, with the details obscured? Thanks!



✎ Dan McInerney modified the Severity from Critical (10) to Critical (10) 2 years ago



Dan McInerney commented 2 years ago

Admin

Hi haxatron,

As it's been 45 days with no maintainer response, we manually replicated this finding. Both read and write are working. Great catch. It should be noted for posterity that rather than full system access, this allows only the parent directory and subdirectory access as the LFI filtering against payloads such as "../../../ssh/id_rsa" appears to be working correctly. We are doing some backend maintenance at this moment but we will mark this finding valid in a few days when maintenance is over.

Thanks, Dan McInerney Lead Threat Researcher

Thanks, Dan McInerney Lead Threat Researcher



haxatron commented 2 years ago

Researcher

Hello @danmcinerney, Thank you very much for the assessment here! Do you know when the backend maintenance will be done? Also, I noticed that ML severity now has 1 criteria called "upload", as mlflow allows users to store ML models on the server, would it qualify for this criteria? Thanks!



haxatron modified the report 2 years ago



Ben Harvie modified the report 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Ben Harvie** validated this vulnerability 2 years ago

\$ **haxatron** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



haxatron commented 2 years ago

Researcher

Hi, I am assuming the reward displayed is the grandfathered amount?



Dan McInerney commented 2 years ago

Admin

That is correct, the payment was fixed to reflect the higher previous payments we had when this report was created.



haxatron commented 2 years ago

Researcher

Hi, earlier I uploaded a patch to huntr. As it has been 45 days, what should be done with the patch?



haxatron commented 2 years ago

Researcher

Discussed with @danmcinerney on Discord and @danmcinerney suggested to send a PR.

PR: <https://github.com/mlflow/mlflow/pull/10327>



haxatron commented 2 years ago

Researcher

resent: <https://github.com/mlflow/mlflow/pull/10330>



This vulnerability has now been published 2 years ago



haxatron commented 2 years ago

Researcher

Just FYI:

This was fixed in

<https://github.com/mlflow/mlflow/commit/cf83dad4df26dd4a850622fe8a51ccab1471a5e7>
and released in 2.8.1. Waiting for @danmcinerney to validate and review the fix and mark this as fixed.



Ben Harvie marked this as fixed in **2.8.1** with commit **cf83da** 2 years ago

\$ **haxatron** has been awarded the fix bounty ✓

[Sign in](#) to join this conversation

CVE

CVE-2023-6015

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

Critical (10)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	High
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

<= 2.6.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$30485

Fix Bounty

\$7621.25

Found by



haxatron

@haxatron

LIGHTWEIGHT



Fixed by



haxatron

@haxatron

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)